

Generated artefact

SOA — Statement of Applicability

Version 8f96c01d1ee0 · generated · classification internal

Artefact	SOA
Generated from	the ISMS sources (front matter, registers, catalogue)
Source digest	sha256:8f96c01d1ee0829b...
Maintained by	Information Security Officer / ISMS Manager (Alex Rossi)
Approved by	Managing Director (Dana Weber)

Digital signature. When this PDF is produced by the release pipeline it carries a PAdES signature of the ISMS document-control key, shown at the bottom of this page; verify it with `isms verify` or any PDF reader. An unsigned copy is not a controlled document.

Digital signature (PAdES) — applied by the release pipeline. An unsigned copy is not a controlled document.

Digitally signed by
ISMS Document Control - UNTRUSTED DEVELOPMENT KEY
2026-08-20 22:09:21 CEST
UNTRUSTED DEVELOPMENT KEY - not a controlled copy

The Statement of Applicability lists every control of ISO/IEC 27001:2022 Annex A, whether it is applicable, why it is included or excluded, how far it is implemented, which approved documents implement it, which risks of the risk register it treats and who owns it (clause 6.1.3 d). It is generated from the control implementation guides under `isms/controls/`, the document set and the risk register; change those sources, not this file.

Scope. Group-level statement covering all in-scope entities (PaketPort AT, PaketPort DE, PaketPort CZ). Entity-specific statements with local applicability decisions are generated alongside this file under `soa/`.

Standard. ISO/IEC 27001:2022 Annex A. Control titles only; descriptive text is original. Controls introduced with the 2022 revision are marked with (new).

Summary

Theme	Controls	Applicable	Implemented	Partially implemented	Planned	Not implemented	Not applicable
Organizational controls (A.5)	37	37	33	4	0	0	0
People controls (A.6)	8	8	8	0	0	0	0
Physical controls (A.7)	14	14	13	1	0	0	0
Technological controls (A.8)	34	34	29	4	1	0	0
All themes	93	93	83	9	1	0	0

22 approved documents implement the applicable controls; 13 of the 13 risks in the register are referenced as justification.

Organizational controls (A.5)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.5.1	Policies for information security	Yes	Required by ISO/IEC 27001 clause 5.2 and by NIS2 Art. 20 and 21 (LEG-01, LEG-04); the management body (IP-06) and the competent authority (IP-04) expect an approved, communicated policy set. Treats R-012.	implemented	POL-ISMS	R-012	Information Security Officer / ISMS Manager	3 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.5.2	Information security roles and responsibilities	Yes	Clause 5.3 and NIS2 Art. 20 (LEG-01) require assigned and communicated responsibilities; with three entities and a two-person security function, explicit role ownership is what keeps the ISMS operating (supports R-012 and R-013).	implemented	POL-ORG	—	Information Security Officer / ISMS Manager	3 item(s)
A.5.3	Segregation of duties	Yes	Treats R-010 (insider misuse of privileged access) by separating development from release signing, request from approval, and operation from audit; a small team makes technically enforced and compensating controls essential.	implemented	POL-ORG	R-010	Information Security Officer / ISMS Manager	3 item(s)
A.5.4	Management responsibilities	Yes	Clause 5.1 and NIS2 Art. 20 make the management body accountable for the risk-management measures (LEG-01); the shareholders (IP-06) expect demonstrable governance. Treats R-012.	implemented	POL-ISMS	R-012	Information Security Officer / ISMS Manager	3 item(s)
A.5.5	Contact with authorities	Yes	NIS2 registration and incident reporting (LEG-01, IP-04) depend on current contacts with the competent authority and CSIRT in each country; treats R-012.	implemented	POL-ORG, PROC-IR	R-012	Information Security Officer / ISMS Manager	3 item(s)
A.5.6	Contact with special interest groups	Yes	Internet-facing lockers are a known target; membership of the CSIRT community and sector associations provides early warnings and peer practice (supports R-007 and R-001).	implemented	POL-ORG	—	Information Security Officer / ISMS Manager	3 item(s)
A.5.7	Threat intelligence (new)	Yes	Treats R-007 (exploitation of unpatched vulnerabilities) and improves detection for R-002; part of the cyber-hygiene measures of NIS2 Art. 21(2)(g) (LEG-01). The programme is young; sources and weekly triage exist, automated enrichment of detections is still being built.	partially implemented	POL-IR	R-007	Security Engineer	2 item(s)
A.5.8	Information security in project management	Yes	Locker roll-outs, carrier integrations and new entities are how risk enters PaketPort; security gates in projects prevent retrofitting controls (supports R-006 and R-009).	implemented	POL-ORG	—	Information Security Officer / ISMS Manager	2 item(s)
A.5.9	Inventory of information and other associated assets	Yes	A locker nobody knows about cannot be patched, monitored or recovered; the inventory underpins vulnerability management, backup and incident response for a dispersed estate and the knowledge inventory supports R-013. NIS2 Art. 21(2)(i).	implemented	POL-CLS	R-013	IT Operations Lead	3 item(s)
A.5.10	Acceptable use of information and other associated assets	Yes	Staff and technicians (IP-07) need clear rules for using systems, data and locker tooling; acceptable-use rules are the behavioural side of R-004 and R-005 and a NIS2 cyber-hygiene measure.	implemented	POL-AUP	—	IT Operations Lead	2 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.5.11	Return of assets	Yes	Leavers and technicians hold laptops, tablets, locker keys and master keys; unreturned assets are a direct path into lockers and systems (supports R-004 and R-001).	implemented	POL-CLS	—	IT Operations Lead	2 item(s)
A.5.12	Classification of information	Yes	Consumer personal data, carrier credentials, firmware signing keys and public locker locations need very different handling; classification drives the handling rules, encryption and access decisions (supports R-009).	implemented	POL-CLS	—	Information Security Officer / ISMS Manager	3 item(s)
A.5.13	Labelling of information	Yes	Labels make classification visible to people and enforceable by tools — subject prefixes, repository metadata and cloud tags are how the handling rules are applied in practice.	implemented	POL-CLS	—	Information Security Officer / ISMS Manager	2 item(s)
A.5.14	Information transfer	Yes	Parcel events and personal data flow between lockers, backend, carriers and suppliers every minute; transfer rules and agreements protect them in motion (supports R-009; NIS2 Art. 21(2)(j) secured communications).	implemented	POL-AUP, POL-CLS	—	Information Security Officer / ISMS Manager	3 item(s)
A.5.15	Access control	Yes	Treats R-004 (unauthorised access via weak authentication or stale accounts) and R-010 (insider misuse of privileged access). Required by NIS2 Art. 21(2)(i) (LEG-01), by the cyber insurance conditions (LEG-08) and by the security annex of the carrier agreements (IP-02).	implemented	POL-ACC	R-004, R-010	Information Security Officer / ISMS Manager	3 item(s)
A.5.16	Identity management	Yes	Treats R-004: stale and shared identities are the most common path to unauthorised access; every person, service and locker needs a unique, traceable identity (NIS2 Art. 21(2)(i)).	implemented	POL-ACC	R-004	IT Operations Lead	2 item(s)
A.5.17	Authentication information	Yes	Treats R-004: weak, reused or shared credentials are the cheapest attack; the standard fixes lengths, screening, issuance and reset rules (NIS2 Art. 21(2)(j); insurer condition LEG-08).	implemented	POL-ACC, STD-AUTH	R-004	Security Engineer	3 item(s)
A.5.18	Access rights	Yes	Treats R-004: over-provisioned and never-reviewed rights turn one compromised account into broad access; approval and periodic review are also carrier and insurer expectations (LEG-05, LEG-08).	implemented	POL-ACC	R-004	IT Operations Lead	3 item(s)
A.5.19	Information security in supplier relationships	Yes	Treats R-006 (supplier or cloud provider compromise): carriers, the cloud provider, the hardware manufacturer and the German subcontractors all hold access or deliver components; NIS2 Art. 21(2)(d).	implemented	POL-SUP	R-006	Head of Procurement	2 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.5.20	Addressing information security within supplier agreements	Yes	Carriers (IP-02) and suppliers (IP-08) need security requirements in writing; LEG-05 makes the carrier security annex a contractual obligation. Treats R-006.	implemented	POL-SUP	R-006	Head of Procurement	2 item(s)
A.5.21	Managing information security in the ICT supply chain	Yes	Locker controllers and firmware components come from suppliers; a compromised component would reach the whole fleet (R-006), and the Cyber Resilience Act expects bill-of-materials management (LEG-03). Partially implemented: bills of materials exist for firmware and backend, hardware provenance attestations are still being collected.	partially implemented	POL-SUP	R-006	Head of Procurement	2 item(s)
A.5.22	Monitoring, review and change management of supplier services	Yes	Supplier posture changes after onboarding; annual reviews and change notification keep assurance current (R-006; LEG-05 attestations). Partially implemented: tier 1 reviews run, the tier 2 review cycle is being scheduled.	partially implemented	POL-SUP	R-006	Head of Procurement	2 item(s)
A.5.23	Information security for use of cloud services (new)	Yes	The backend runs entirely on one cloud provider under a shared-responsibility model (LEG-07, IP-08); misconfiguration on PaketPort's side is the realistic failure mode (R-006, R-004).	implemented	POL-SUP	R-006	Head of Platform & SRE	3 item(s)
A.5.24	Information security incident management planning and preparation	Yes	Treats R-002 and R-012: NIS2 Art. 21(2)(b) and Art. 23 (LEG-01) require a prepared incident process with a 24-hour early warning; preparation is what makes the deadlines achievable.	implemented	POL-IR, PROC-IR	R-002, R-012	Information Security Officer / ISMS Manager	3 item(s)
A.5.25	Assessment and decision on information security events	Yes	Treats R-002: the significance test and the awareness time decide whether the 24-hour NIS2 clock is running; fast, recorded triage is the difference between compliance and a missed deadline.	implemented	POL-IR, PROC-IR	R-002	Information Security Officer / ISMS Manager	2 item(s)
A.5.26	Response to information security incidents	Yes	Treats R-002 and R-011: controlled containment, eradication and recovery limit the damage to the service and the data and are the substance of NIS2 Art. 21(2)(b).	implemented	POL-IR, PROC-IR	R-002	Information Security Officer / ISMS Manager	2 item(s)
A.5.27	Learning from information security incidents	Yes	Post-incident reviews convert incidents into stronger controls and updated risks (NIS2 Art. 21(2)(f) effectiveness). Partially implemented: reviews are held for S1 and S2, the structured sharing of lessons across the three entities is being established.	partially implemented	POL-IR	—	Information Security Officer / ISMS Manager	3 item(s)
A.5.28	Collection of evidence	Yes	Treats R-008: evidence that can stand up before authorities, insurers and courts requires disciplined collection with chain of custody; locker controllers are physical evidence that travels.	implemented	POL-IR, PROC-IR	R-008	Information Security Officer / ISMS Manager	2 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.5.29	Information security during disruption	Yes	Treats R-003: recovery under pressure is when controls get switched off; keeping access control, logging and encryption in force during disruption prevents a second incident.	implemented	POL-BC	R-003	Head of Platform & SRE	2 item(s)
A.5.30	ICT readiness for business continuity (new)	Yes	Treats R-003 and R-011: customers must collect parcels and carriers must hand over even when the backend fails; NIS2 Art. 21(2)(c) requires business continuity and disaster recovery.	implemented	POL-BC	R-003, R-011	Head of Platform & SRE	3 item(s)
A.5.31	Legal, statutory, regulatory and contractual requirements	Yes	Treats R-012: NIS2 (LEG-01), the GDPR, the Cyber Resilience Act and the carrier contracts differ per entity and change; an owned, reviewed legal register is the only way to keep the ISMS aligned with them.	implemented	POL-LEG	R-012	Information Security Officer / ISMS Manager	3 item(s)
A.5.32	Intellectual property rights	Yes	Firmware and backend embed open-source components with licence obligations, and PaketPort's own code is a core asset; licence compliance and IP protection are legal duties and part of the Cyber Resilience Act documentation (LEG-03).	implemented	POL-LEG	—	Information Security Officer / ISMS Manager	2 item(s)
A.5.33	Protection of records	Yes	Handover records, financial records, ISMS records and incident reports have statutory retention and must stay intact and retrievable (LEG-02 accountability, certification, NIS2 evidence).	implemented	POL-LEG	—	Data Protection Officer	3 item(s)
A.5.34	Privacy and protection of personally identifiable information (PII)	Yes	PaketPort processes the personal data of every locker user; the GDPR (LEG-02), consumers (IP-01) and the data protection authorities (IP-05) require lawful processing, an independent DPO, breach notification and privacy by design (supports R-009).	implemented	POL-LEG	—	Data Protection Officer	4 item(s)
A.5.35	Independent review of information security	Yes	Certification (LEG-04) and the certification body (IP-09) require an independent audit programme and reviews; NIS2 Art. 21(2)(f) asks for the assessment of effectiveness.	implemented	POL-ISMS, PROC-AUDIT	—	Internal Audit Lead	3 item(s)
A.5.36	Compliance with policies, rules and standards for information security	Yes	Policies that are not checked erode; regular compliance checks by owners, automation and spot checks are how PaketPort knows its rules are followed (LEG-04; NIS2 Art. 21(2)(f)).	implemented	POL-ISMS, PROC-CAPA	—	Information Security Officer / ISMS Manager	3 item(s)
A.5.37	Documented operating procedures	Yes	Treats R-013 (bus factor) and satisfies clause 7.5 and the certification body (IP-09, LEG-04): procedures and runbooks must be written, controlled and available to the people who operate the platform and the ISMS.	implemented	PROC-DOC	R-013	Information Security Officer / ISMS Manager	3 item(s)

People controls (A.6)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.6.1	Screening	Yes	People with privileged access, access to personal data, firmware signing rights or field access to lockers need proportionate screening within the limits of local labour law (LEG-06); supports R-010.	implemented	POL-HR	—	HR Manager	2 item(s)
A.6.2	Terms and conditions of employment	Yes	Security responsibilities and confidentiality must be contractual to be enforceable; NIS2 Art. 21(2)(i) human-resources security.	implemented	POL-HR	—	HR Manager	2 item(s)
A.6.3	Information security awareness, education and training	Yes	Treats R-005 (phishing) and meets NIS2 Art. 21(2)(g) and the Art. 20 management training duty (LEG-01); staff and technicians (IP-07) need training that fits their role, including locker tampering for the field.	implemented	POL-HR	R-005	HR Manager	3 item(s)
A.6.4	Disciplinary process	Yes	A fair, known process is what makes the consequences in the policies credible and legally sound across three jurisdictions; it also protects good-faith reporters.	implemented	POL-HR	—	HR Manager	2 item(s)
A.6.5	Responsibilities after termination or change of employment	Yes	Confidentiality, return of information and handover of knowledge continue after departure; leavers with platform knowledge are a bus-factor and insider consideration (R-013, R-010).	implemented	POL-HR	—	HR Manager	2 item(s)
A.6.6	Confidentiality or non-disclosure agreements	Yes	Customer, carrier and site-host information and PaketPort's firmware are shared with staff, contractors and visitors; enforceable confidentiality agreements protect them beyond the relationship.	implemented	POL-HR	—	HR Manager	2 item(s)
A.6.7	Remote working	Yes	Hybrid office work and an entirely mobile field service make remote working the normal case (IP-07); rules for devices, networks and workspaces protect information outside the office (supports R-004 and R-005).	implemented	POL-AUP	—	IT Operations Lead	2 item(s)
A.6.8	Information security event reporting	Yes	Treats R-002 and R-005: people are the first sensor for phishing, tamper and misuse; a fast, no-blame channel is the cheapest detection PaketPort has (IP-07; NIS2 Art. 21(2)(b)).	implemented	POL-IR, PROC-IR	R-002, R-005	Information Security Officer / ISMS Manager	3 item(s)

Physical controls (A.7)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.7.1	Physical security perimeters	Yes	Treats R-001: lockers stand on public streets and the depot holds controllers and keys; defined perimeters and zones make physical protection deliberate (site hosts IP-03).	implemented	POL-PHY	R-001	Facilities & Physical Security Lead	2 item(s)
A.7.2	Physical entry	Yes	Badge-controlled entry, visitor management and per-visit locker authorisation keep people out of rooms and enclosures they have no business in (supports R-001 and R-010).	implemented	POL-PHY	—	Facilities & Physical Security Lead	3 item(s)
A.7.3	Securing offices, rooms and facilities	Yes	Server rooms, the key-handling room and the depot cage hold keys, controllers and forensic evidence; locked, unsignposted and purpose-limited rooms reduce opportunistic and targeted access (supports R-001 and R-010).	implemented	POL-PHY	—	Facilities & Physical Security Lead	2 item(s)
A.7.4	Physical security monitoring (new)	Yes	Treats R-001: tamper detection on lockers and intrusion detection at the head office and the depot turn a physical attack into an alert the security operations centre can act on (IP-03). Partially implemented: older locker generations lack enclosure sensors and are scheduled for retrofit.	partially implemented	POL-PHY	R-001	Facilities & Physical Security Lead	3 item(s)
A.7.5	Protecting against physical and environmental threats	Yes	Fire, water and power affect server rooms and the depot; weather, flooding and vandalism affect street lockers; environmental protection keeps the service available (supports R-003).	implemented	POL-PHY	—	Facilities & Physical Security Lead	2 item(s)
A.7.6	Working in secure areas	Yes	Work in server rooms and the key-handling room is where keys and evidence are exposed; two-person rules and recording limit insider and accidental risk (supports R-010).	implemented	POL-PHY	—	Facilities & Physical Security Lead	1 item(s)
A.7.7	Clear desk and clear screen	Yes	Printed manifests, credentials on notes and unlocked screens in offices, the depot and vehicles are easy wins for an intruder or a visitor; the rule is simple and checkable.	implemented	POL-AUP	—	IT Operations Lead	2 item(s)
A.7.8	Equipment siting and protection	Yes	Treats R-001: how a locker is anchored, where its controller compartment faces and how its cables run decide how easy tampering is; the same applies to racks and screens in the offices.	implemented	POL-PHY	R-001	Facilities & Physical Security Lead	2 item(s)
A.7.9	Security of assets off-premises	Yes	Technician laptops, tablets, tools, spare parts and locker units are outside PaketPort premises every day; loss or theft of a tablet with maintenance access or a controller with keys is a direct risk (supports R-001 and R-004).	implemented	POL-PHY	—	Facilities & Physical Security Lead	3 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.7.10	Storage media	Yes	Removable media and the storage inside lockers and controllers carry keys, buffered transactions and backups; encryption, registration and disposal rules prevent leakage (supports R-001 and R-009).	implemented	POL-CLS	—	IT Operations Lead	2 item(s)
A.7.11	Supporting utilities	Yes	Power and connectivity failures at the head office, the SOC or a locker site interrupt the service; uninterruptible power and safe locker behaviour on power loss protect availability (supports R-003 and R-011).	implemented	POL-PHY	—	Facilities & Physical Security Lead	2 item(s)
A.7.12	Cabling security	Yes	Exposed cabling at locker sites and in offices invites tapping and disruption; protected conduits and treating the locker uplink as untrusted limit the impact.	implemented	POL-PHY	—	Facilities & Physical Security Lead	2 item(s)
A.7.13	Equipment maintenance	Yes	Maintenance is when equipment is opened and technicians — including subcontractors — have their hands on controllers; authorised, recorded maintenance keeps integrity and evidence (supports R-001).	implemented	POL-PHY	—	Facilities & Physical Security Lead	2 item(s)
A.7.14	Secure disposal or re-use of equipment	Yes	Decommissioned lockers, controllers, laptops and media leave PaketPort's control; wiping, certificate revocation and destruction certificates prevent data and key leakage (supports R-001 and R-009).	implemented	POL-PHY	—	Facilities & Physical Security Lead	2 item(s)

Technological controls (A.8)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.8.1	User endpoint devices	Yes	Laptops, phones and maintenance tablets are where phishing lands and where confidential data is handled; managed, encrypted, patched endpoints without local administrator rights limit R-004 and R-005.	implemented	POL-AUP	—	IT Operations Lead	2 item(s)
A.8.2	Privileged access rights	Yes	Treats R-004 and R-010: privileged access to the backend, the fleet-management plane and the identity provider is the most damaging access to lose or misuse; NIS2 Art. 21(2)(i).	implemented	POL-ACC	R-004, R-010	Information Security Officer / ISMS Manager	3 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.8.3	Information access restriction	Yes	Treats R-004 and supports R-009: consumer personal data and restricted keys must be reachable only by roles with a purpose; restriction by classification makes least privilege concrete.	implemented	POL-ACC	R-004	Information Security Officer / ISMS Manager	2 item(s)
A.8.4	Access to source code	Yes	Firmware and backend source code is confidential and the route to the fleet; write access through reviewed pull requests, protected release branches and restricted signing rights prevent unauthorised changes (supports R-009 and R-001).	implemented	POL-SDLC	—	Software Engineering Lead	2 item(s)
A.8.5	Secure authentication	Yes	Treats R-004 and R-005: multi-factor and phishing-resistant authentication is the most effective control against credential attacks; required by the insurer (LEG-08, IP-10) and NIS2 Art. 21(2)(j).	implemented	POL-ACC, STD-AUTH	R-004, R-005	Security Engineer	3 item(s)
A.8.6	Capacity management	Yes	Treats R-011: the API must absorb peaks and attacks, and fleet-wide firmware roll-outs must not starve the management plane; capacity planning keeps the service available. Partially implemented: monitoring and autoscaling exist, quarterly forecasting from parcel volumes is being introduced.	partially implemented	POL-LOG	R-011	Head of Platform & SRE	2 item(s)
A.8.7	Protection against malware	Yes	Endpoints, servers and the mail gateway are exposed to malware daily, and ransomware in production would threaten the service; the insurer requires endpoint protection (LEG-08); NIS2 Art. 21(2)(g).	implemented	POL-VULN	—	Security Engineer	3 item(s)
A.8.8	Management of technical vulnerabilities	Yes	Treats R-007 and R-009: unpatched lockers, backend services and dependencies are the likeliest entry point; the Cyber Resilience Act (LEG-03) and NIS2 Art. 21(2)(e) require vulnerability handling with deadlines and disclosure.	implemented	POL-VULN	R-007, R-009	Security Engineer	3 item(s)
A.8.9	Configuration management (new)	Yes	Treats R-001, R-007 and R-013: baselines as code make lockers, cloud and endpoints reproducibly secure and recoverable, and drift detection catches silent weakening (LEG-07 shared responsibility).	implemented	POL-VULN	R-001, R-007, R-013	Security Engineer	3 item(s)
A.8.10	Information deletion (new)	Yes	GDPR storage limitation (LEG-02) and the records schedule require deletion when the purpose ends; decommissioned lockers and cloud storage must not keep data behind (supports R-009).	implemented	POL-CLS	—	Data Protection Officer	3 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.8.11	Data masking (new)	Yes	Treats R-009: development, test and analytics should never expose real consumer data; masking and synthetic data remove the exposure. Planned: the rule exists in POL-CLS, the masking tooling for all data stores is being built under the risk treatment plan.	planned	POL-CLS	R-009	Software Engineering Lead	1 item(s)
A.8.12	Data leakage prevention (new)	Yes	Bulk exports of consumer data and uncontrolled channels are the realistic leakage paths (supports R-009 and R-010); monitoring and restriction are proportionate to classification. Partially implemented: export alerts and USB blocking are live, outbound content inspection is being tuned.	partially implemented	POL-CLS	—	Security Engineer	2 item(s)
A.8.13	Information backup	Yes	Treats R-003: ransomware or a region failure must not destroy the only copy; the insurer (LEG-08, IP-10) and NIS2 Art. 21(2) (c) require tested, isolated backups.	implemented	POL-BC	R-003	Head of Platform & SRE	3 item(s)
A.8.14	Redundancy of information processing facilities	Yes	Treats R-003 and R-011: single points of failure in the backend, the locker uplinks or the spare-parts supply would stop the service; redundancy underpins the recovery objectives.	implemented	POL-BC	R-003	Head of Platform & SRE	3 item(s)
A.8.15	Logging	Yes	Treats R-002, R-008 and R-010: detection, forensics and NIS2 reporting all depend on complete, tamper-evident logs; LEG-06 limits monitoring of staff and shapes what is logged.	implemented	POL-LOG	R-002, R-008, R-010	Head of Platform & SRE	3 item(s)
A.8.16	Monitoring activities (new)	Yes	Treats R-002 and R-008: logs are useless without someone watching; detection use cases and round-the-clock alert handling are what achieve the NIS2 deadlines. Partially implemented: core use cases and SOC coverage exist, anomaly detection for API usage and automated intelligence enrichment are being added.	partially implemented	POL-LOG	R-002, R-008	Head of Platform & SRE	3 item(s)
A.8.17	Clock synchronization	Yes	Treats R-008: correlating events across lockers, backend and identity provider during an investigation requires synchronised clocks, and timelines reported to authorities must be accurate.	implemented	POL-LOG	R-008	Head of Platform & SRE	2 item(s)
A.8.18	Use of privileged utility programs	Yes	Treats R-010: database consoles, fleet administration tools and system utilities can bypass application controls; restricting them to named roles through the bastion with session recording keeps them accountable.	implemented	POL-ACC	R-010	Head of Platform & SRE	2 item(s)
A.8.19	Installation of software on operational systems	Yes	Treats R-007: unapproved or unsupported software on servers, lockers and endpoints is unpatched software; controlled installation keeps the estate known and patchable (NIS2 Art. 21(2)(g)).	implemented	POL-AUP, POL-VULN	R-007	IT Operations Lead	3 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.8.20	Networks security	Yes	Treats R-011 and supports R-001 and R-004: the APIs face the internet and the lockers connect over untrusted networks; firewalls, denial-of-service protection, authenticated remote access and mutual TLS are the backbone (NIS2 Art. 21(2)(j)).	implemented	POL-NET	R-011	Head of Platform & SRE	3 item(s)
A.8.21	Security of network services	Yes	Treats R-011: connectivity, cellular data and content-delivery services are bought in; their security features and service levels must be specified and monitored (LEG-05 carrier API commitments, IP-02).	implemented	POL-NET	R-011	Head of Platform & SRE	2 item(s)
A.8.22	Segregation of networks	Yes	Production, the management plane, corporate IT, the lab and the untrusted locker estate must not share trust; segregation limits the blast radius of a compromised locker, laptop or test unit (supports R-001 and R-004; NIS2 Art. 21(2)(j)).	implemented	POL-NET	—	Head of Platform & SRE	3 item(s)
A.8.23	Web filtering (new)	Yes	Treats R-005: malicious and phishing sites deliver credential theft and malware; filtering on all managed devices, including field laptops, blocks them early (NIS2 Art. 21(2)(g)). Partially implemented: office and VPN traffic is filtered, always-on filtering for field-service tablets is being rolled out.	partially implemented	POL-AUP, POL-NET	R-005	Head of Platform & SRE	2 item(s)
A.8.24	Use of cryptography	Yes	Treats R-001 and R-009: mutual TLS and signed firmware protect the lockers, encryption at rest and in transit protects consumer data; NIS2 Art. 21(2)(h) and the Cyber Resilience Act require managed cryptography.	implemented	POL-CRYP, STD-CRYPTO	R-001, R-009	Head of Platform & SRE	4 item(s)
A.8.25	Secure development life cycle	Yes	Treats R-009: security built into the requirements, design, coding, testing and release of firmware, backend and app; required for the locker product by the Cyber Resilience Act (LEG-03) and by NIS2 Art. 21(2)(e).	implemented	POL-SDLC	R-009	Software Engineering Lead	2 item(s)
A.8.26	Application security requirements	Yes	Treats R-009: without explicit requirements for authentication, authorisation, input validation, cryptography and logging, features ship insecure; the locker product's essential requirements under the Cyber Resilience Act must be documented.	implemented	POL-SDLC	R-009	Software Engineering Lead	2 item(s)
A.8.27	Secure system architecture and engineering principles	Yes	Defence in depth, least privilege, fail-secure lockers and no implicit trust between locker, backend and app are what keep a single flaw from becoming a fleet-wide compromise (supports R-001 and R-009).	implemented	POL-SDLC	—	Software Engineering Lead	2 item(s)

Control	Title	Applicable	Justification	Implementation status	Implemented by	Risks	Owner	Evidence
A.8.28	Secure coding (new)	Yes	Treats R-009: injection, memory errors in firmware and leaked secrets are coding defects; a coding standard with automated checks and four-eyes review prevents them (LEG-03; NIS2 Art. 21(2)(e)).	implemented	POL-SDLC	R-009	Software Engineering Lead	2 item(s)
A.8.29	Security testing in development and acceptance	Yes	Treats R-009: static and dynamic testing, hardware-in-the-loop firmware tests and annual penetration tests find what reviews miss before attackers do.	implemented	POL-SDLC	R-009	Software Engineering Lead	2 item(s)
A.8.30	Outsourced development	Yes	Treats R-006: code written by an external developer enters PaketPort's products; contracts, access limits, testing before acceptance and no production data keep it to the same standard (LEG-03 for product components; NIS2 Art. 21(2)(d)).	implemented	POL-SUP	R-006	Head of Procurement	2 item(s)
A.8.31	Separation of development, test and production environments	Yes	Separate development, test, staging and production with separate credentials and no production data stop a test mistake or a compromised developer account from reaching the fleet or consumer data (supports R-009 and R-004).	implemented	POL-SDLC	—	Software Engineering Lead	2 item(s)
A.8.32	Change management	Yes	Uncontrolled changes to production, the fleet or the ISMS cause outages and security gaps; typed changes with approval, testing, rollback and staged firmware roll-outs keep change safe (NIS2 Art. 21(2)(e); clause 6.3).	implemented	POL-SDLC	—	Software Engineering Lead	3 item(s)
A.8.33	Test information	Yes	Real consumer data in test systems would extend the breach surface to every developer laptop and lab unit (supports R-009); masked or synthetic test data removes it.	implemented	POL-SDLC	—	Software Engineering Lead	2 item(s)
A.8.34	Protection of information systems during audit testing	Yes	Audits and penetration tests touch production and the fleet; read-only access, approved windows and confidential handling of audit data prevent the assurance activity from causing an incident.	implemented	PROC-AUDIT	—	Internal Audit Lead	2 item(s)

Approval

Maintained by the Information Security Officer / ISMS Manager; approved by the Managing Director as part of the risk treatment plan (PROC-RISK). Approval and every subsequent change are recorded in version control through the pull-request history of the control guides.

Approval and control

Generated artefact. It is derived deterministically from the repository sources and regenerated by CI on every change; the approval record is the version-control history of the sources it is generated from.

Source digest sha256:8f96c01d1ee0829b7d819adde4910493a90efc651dff88f8739caa0026f3e31d · rendered by isms-as-code from the repository sources.